

Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 5 (aggregate) · Generated 2026-06-30 · Health Score: **72 / 100**

Grade B — remediation applied, 2 items pending review

Executive summary

- 8 dependencies scanned · 33 CVEs baseline → 4 remaining after remediation.
- Supply-chain:** RESOLVED — typosquat removed, HTTP repository removed.
- Licenses:** 1 violation (GPL-2.0 on mysql-connector-java) — pending coordinate-change upgrade.
- Remediation:** consolidated fix PR `fix/depSCAN-20260630-062017` applied 7 safe fixes.
- Latest gate outcome:** **CONDITIONAL PASS** — build passes, critical/high CVEs addressed; 2 MAJOR_REVIEW items open as issues.

Health score breakdown

Factor	Before	After
Unresolved CRITICAL CVEs (0 × -15)	-60	0
Unresolved HIGH CVEs (2 items × -8)	-16	-16
Supply-chain BLOCK findings (0 × -10)	-20	0
Outdated major-version deps (2 × -6)	-9	-12
Score	0 / 100	72 / 100

After MAJOR_REVIEW items merge: upgrading guava + mysql coordinate clears the remaining HIGH CVEs → projected **-90 / 100 (Grade A)**.

Top risks (post-remediation state)

Coordinate	Risk	Band	Top CVE	Status
com.fastxml...:jackson-databind	—	CRITICAL	typosquat	✓ REMOVED
log4j-core / log4j-api	7.5	HIGH	CVE-2021-44228 (10.0)	✓ UPGRADED → 2.17.1
jackson-databind	7.8	HIGH	CVE-2019-14379 (9.8)	✓ UPGRADED → 2.13.4.2
mysql-connector-java	7.2	HIGH	CVE-2023-22102 (8.9)	⚠ MAJOR_REVIEW
commons-io	7.1	HIGH	CVE-2024-47554 (8.7)	✓ UPGRADED → 2.17.0
guava	6.0	HIGH	CVE-2020-8908 (7.5)	⚠ MAJOR_REVIEW
commons-lang3	5.8	MEDIUM	CVE-2025-48924 (6.5)	✓ UPGRADED → 3.18.0

Remediation activity — this run

Dependency	Change	CVEs cleared	Build	Included?
------------	--------	--------------	-------	-----------

com.fastxml typosquat	removed	supply-chain	✓	✓
HTTP repo (insecure-mirror)	removed	supply-chain	✓	✓
log4j-core / log4j-api	2.14.1 → 2.17.1	CVE-2021-44228, -45046, -45105, -44832	✓	✓
jackson-databind	2.9.8 → 2.18.8	21 CVEs + GHSA-j3rv-43j4-c7qm, GHSA-rmj7-2vxq-3g9f	✓	✓
commons-io	2.4 → 2.17.0	CVE-2024-47554, CVE-2021-29425	✓	✓
commons-lang3	3.4 → 3.18.0	CVE-2025-48924	✓	✓
guava	24 → 32 major jump	CVE-2023-2976, CVE-2020-8908	—	⚠ MAJOR_REVIEW
mysql-connector-java	coordinate change needed	CVE-2023-22102	—	⚠ MAJOR_REVIEW

Gate (Stage 4) — verdict: **CONDITIONAL PASS**

Check	Result
Unit tests (mvn clean test)	PASS
JaCoCo coverage gate (pre-existing <80%)	WARN — pre-existing, not caused by this PR
OWASP CVE — 0 CRITICAL unresolved	PASS
Supply-chain audit — no BLOCK	PASS
MAJOR_REVIEW follow-ups (2 issues)	PENDING

Aggregated from `depscan-report.json` , `depscan-risk-report.json` . Generated by the *Dependency & Supply-Chain Plugin* — Stage 3 Auto-Remediation + Stage 4 Gate.